CONTENTS

Read this first

Keyword spotting

5.1 Persistence

5.2 Lateral movement

5.3 Staging and exfiltration

5.4 Cleanup and restoration

Tie-breakers and exam logic

Self-check — 30 questions

Term list for flashcards

One-page cram sheet

Seven-day plan

Domain 5.0
Post-exploitation & Lateral Movement

14%	12–13	4	PBQ
OF THE EXAM	QUESTIONS OF 90	OBJECTIVES (5.1–5.4)	HEAVY ZONE

00 Read this first

Everything in Domain 5 happens *after* you already have a shell. Domain 4 got you in; Domain 5 is the question "you're on the box — now what?" If a scenario opens with "a tester has gained initial access to a workstation…" you are in this domain, and the exploit is behind you.

This domain carries more weight than its 14% suggests, because it is where the **performance-based questions** cluster — drag-and-drop kill chains, "pick the command," and "order these steps." Recognition-level flashcard knowledge is not enough for the PBQs; you need to know *which tool does which job on which port* well enough to act, not just recognize.

> HOW TO USE THIS GUIDE
>
> 1. **Burn in the five-phase timeline below first.** Every question in this domain hangs off knowing which phase a task belongs to. Nothing else here makes sense until that order is automatic.
> 2. **Read straight through once** to build the shape, without trying to memorize.
> 3. **Master the tool→phase→protocol table** in 5.2. Hand-copy it until you can reproduce the port and protocol for each tool from memory. That one table answers most of the domain.
> 4. **Flashcard the vocabulary** for 5.1, 5.3, and 5.4 — those objectives are recognition-heavy and cheap to lock down.
> 5. **Do the 30 self-check questions cold,** then the keyword tables, then the cram sheet.
> 6. **Get hands-on for 5.2 if you possibly can.** Run PsExec, a Proxychains pivot, and a Mimikatz dump in a small lab. The PBQs reward muscle memory that reading cannot build.

The one model that unlocks the whole domain

The four objectives are listed in kill-chain order. Fix this sequence and you can place any tool or task where it belongs:

```
EXPLOIT (D4) → 5.1 PERSISTENCE → 5.2 LATERAL MOVEMENT → 5.3 STAGING & EXFIL → 5.4 CLEANUP
```

Underneath that, almost every tool in this domain answers exactly **one of four questions**. Learn which question a tool answers and you rarely need to memorize more than that:

THE QUESTION	PHASE	REPRESENTATIVE TOOLS / TECHNIQUES
How do I stay?	5.1 Persistence	Scheduled tasks / cron, service creation, registry Run keys, new accounts, C2, web shell, rootkit
How do I reach the next box?	5.2 Lateral movement	PsExec, WMI, WinRM/Evil-WinRM, Impacket, CrackMapExec, Proxychains, sshuttle
How do I get the loot out?	5.3 Staging & exfil	DNS / ICMP / HTTPS tunnels, steganography, alternate data streams, cloud storage
How do I clean up my mess?	5.4 Cleanup	Remove tools, accounts, persistence; revert config; secure data destruction; preserve artifacts



If the stem says the tester already has access, ignore any answer about *gaining* access — scanning, exploiting a CVE, phishing. Those are earlier domains. Domain 5 answers are always about what to do **with** access you already hold.

KW Keyword spotting — how to read a Domain 5 question

These questions are won by matching a phrase in the stem to the phase or tool it points to. Learn these trigger words and you will often find the answer before you finish reading the options.

Phrases that tell you the phase

IF THE STEM SAYS…	THINK	BECAUSE
“maintain access,” “survive a reboot,” “regain access later,” “without re-exploiting”	Persistence (5.1)	The goal is durability, not a new target.
“move to another host,” “reach an internal system,” “expand access,” “the next machine”	Lateral movement (5.2)	A new box is the objective.
“reach a network segment they cannot access directly,” “route traffic through”	Pivoting (5.2)	Compromised host is used as a gateway.
“transfer data out,” “avoid detection by the DLP/SOC,” “blend with normal traffic”	Exfiltration / covert channel (5.3)	Getting loot out past monitoring.
“collect and prepare data before transfer,” “compress and encrypt”	Staging (5.3)	Data is gathered before it leaves.
“conclude the engagement,” “return the environment to its original state,” “remove”	Cleanup (5.4)	The test is ending.

Phrases that tell you the tool

IF THE STEM SAYS…	THE TOOL / TECHNIQUE IS ALMOST CERTAINLY…
“dump credentials from memory / LSASS”	Mimikatz
“execute a command on a remote host over SMB”	PsExec (or Impacket’s psexec)
“run commands remotely using WS-Management / port 5985”	WinRM / Evil-WinRM
“spray a credential across many hosts, check access at scale”	CrackMapExec (CME)
“pass-the-hash / relay / craft Kerberos tickets from Python”	Impacket
“tunnel other tools through a compromised host”	Proxychains (+ SOCKS proxy) or sshuttle
“use a legitimate, signed, built-in Windows binary to avoid detection”	A LOLBin (rundll32, msbuild, certutil, mshta…)
“open-source C2 framework”	Covenant (or Metasploit, Sliver)
“hide data inside an image / audio file”	Steganography
“hide data in an NTFS file stream”	Alternate data streams (ADS)

> **THE DISTRACTOR PATTERN TO EXPECT**
>
> Domain 5 wrong answers are usually *real tools from the wrong phase*. A lateral-movement question will offer Nmap (recon) and sqlmap (web exploitation) as traps. When you have placed the question on the timeline, you can eliminate any option whose phase does not match — often two of the four disappear instantly.

5.1 Establish and maintain persistence

Mostly vocabulary, and the fastest objective here to lock down. The two high-yield distinctions are the **shell types** and the **backdoor family** — expect a question on each.

A · The concept in one line

Persistence is any mechanism that lets you **regain access without repeating the original exploit** — ideally surviving reboots, logouts, and credential changes. If the goal in the stem is durability rather than a new host, you are in 5.1.

B · Reverse shell vs. bind shell — know this cold

SHELL	WHO CONNECTS TO WHOM	WHEN YOU CHOOSE IT	FIREWALL CLUE
Reverse shell	The *target* connects **out** to the attacker's listener.	The default choice. Outbound traffic is usually allowed, so it beats inbound firewalls and NAT.	"target is behind a firewall / NAT," "inbound blocked"
Bind shell	The *target* opens a listener; the **attacker** connects **in**.	Only when an inbound port to the target is reachable.	"target has an open inbound port," "direct access to the host"

> **MEMORY HOOK**
>
> **Reverse** = target **reaches out** to you. **Bind** = target is **bound** to a port, waiting for you. When in doubt on the exam, pick reverse — outbound almost always works and it is the realistic default.

C · Backdoor family — the second guaranteed distinction

TERM	WHAT DEFINES IT	ONE-LINE TELL
Backdoor	Any hidden method of regaining access, bypassing normal authentication. The umbrella term.	"a way back in"
Web shell	A backdoor that is a script on a web server (PHP/ASPX/JSP), driven through HTTP requests.	"uploaded a script to the web server"
Trojan	Malware *disguised* as legitimate software so a user runs it willingly.	"looks like a real program"
Rootkit	Malware built to *hide itself* and other activity, often at kernel level; hardest to detect and remove.	"conceals its own presence"

Relationship: a **trojan** is how it gets there (disguise), a **rootkit** is how it hides (concealment), a **backdoor** is what it provides (access), and a **web shell** is a specific backdoor living on a web server. A single piece of malware can be all four at once.

D · Persistence mechanisms by platform

MECHANISM	HOW IT PERSISTS	WHERE IT LIVES
Scheduled task	Runs your payload on a schedule or trigger (logon, idle).	Windows: Task Scheduler (`schtasks`)
Cron job	The Linux equivalent — runs on a time schedule.	Linux: `crontab`, `/etc/cron.*`
Service creation	Registers a malicious service that auto-starts at boot with high privilege.	Windows services (`sc create`); Linux systemd units
Registry keys	Run / RunOnce keys launch your payload at logon.	Windows: `HKLM\...\Run`, `HKCU\...\Run`
New accounts	Create a local or domain account you control; add to a privileged group.	Local SAM or Active Directory

	privileged group.	
Valid account credentials	Reuse harvested legitimate credentials — the stealthiest persistence, since nothing is "installed."	Dumped hashes, cracked passwords, tokens
Browser extensions	A malicious extension re-establishes access whenever the browser runs.	Chrome/Edge/Firefox profiles

E · The rest of the 5.1 vocabulary

TERM	ONE-LINE DEFINITION
Command and control (C2)	A framework (Covenant, Metasploit, Sliver, Cobalt Strike) that manages compromised hosts and channels commands to them. Persistence + control in one.
Tampering security controls	Disabling or blinding AV/EDR, logging, or firewall rules so your persistence survives and stays quiet.
Obtain valid account credentials	Legitimate creds are the most durable foothold — they look like normal logins and outlast most cleanup.

5.2 Move laterally throughout the environment

The biggest and most PBQ-heavy objective in the domain. Two things carry it: knowing **which remote-execution tool rides which protocol/port**, and understanding **pivoting**. Master those and you have most of the domain's hardest points.

A · What lateral movement actually is

You are on box A. Box B holds what you want, but you cannot exploit it directly. Lateral movement is using what you found on A — credentials, hashes, tickets, trust — to legitimately or semi-legitimately *authenticate* to B. Most of it is not exploitation at all; it is **logging in with stolen keys**. That is why the tools are execution and credential tools, not vulnerability scanners.

B · Service discovery — know the port for each

Before you move, you enumerate what B is running. The exam gives you an open port and asks which service — or names a service and asks the port. Memorize this small table; it is the hinge of the lateral-movement scenarios.

SERVICE	PORT	USED TO MOVE BY…
SMB (fileshares)	445	PsExec, admin shares, hash relay
RDP	3389	Interactive graphical logon
VNC	5900	Interactive graphical logon (cross-platform)
SSH	22	Remote shell / tunneling (Linux & modern Windows)
WinRM	5985 / 5986	Evil-WinRM, PowerShell Remoting
RPC / DCOM	135 (+ dynamic)	WMI execution, DCOM lateral techniques
LDAP	389 / 636	Directory enumeration, BloodHound collection
FTP	21	File transfer, cleartext creds
Telnet	23	Cleartext remote shell (legacy)
HTTP / HTTPS	80 / 443	Web interfaces, web shells, C2 over TLS
LPD / JetDirect	515 / 9100	Printer services — often overlooked footholds

"Cleartext" protocols (FTP, Telnet, LPD, HTTP) are exam gold twice over: they leak credentials to a sniffer *and* they are easy lateral targets. If a scenario mentions capturing traffic, look for these.

C · The master table — tool → job → protocol/port

This is the single most valuable table in the guide. If you can reproduce it from memory, the lateral-movement PBQs become mechanical. Cover the right two columns and drill.

TOOL	WHAT IT DOES	PROTOCOL / PORT	PHASE
PsExec	Execute commands on a remote Windows host using admin shares and a temporary service.	SMB / 445	Lateral exec
WMI (`wmic`, WMIexec)	Run commands remotely via Windows Management Instrumentation — fileless, no service dropped.	RPC/DCOM / 135	Lateral exec
WinRM / Evil-WinRM	Remote PowerShell over WS-Management; Evil-WinRM adds attacker conveniences.	WinRM / 5985–5986	Lateral exec
Impacket	Python toolkit: psexec, smbexec, wmiexec, secretsdump, ticket attacks, relaying.	SMB / RPC / Kerberos	Exec + creds
CrackMapExec (CME)	Swiss-army knife: spray a credential/hash across many hosts.	SMB / WinRM / others	Exec + enum

	check access, execute at scale.		
Mimikatz	Dump credentials, hashes, and tickets from memory (LSASS); pass-the-hash / pass-the-ticket.	Local (LSASS)	Cred access
Netcat	Raw TCP/UDP connections; bind/reverse shells; simple file transfer.	Any TCP/UDP	Shell / transfer
Metasploit	Exploitation + post-exploitation framework; sessions, autoroute, portfwd for pivoting.	Many	Exec + pivot
Covenant	.NET command-and-control framework for managing implants.	HTTP/HTTPS C2	C2
sshuttle	Transparent "poor man's VPN" that routes your traffic through an SSH host.	SSH / 22	Pivot
Proxychains	Forces any tool's traffic through a proxy (usually a SOCKS proxy on a pivot).	SOCKS	Pivot
PowerShell ISE	Scripting/remoting environment used to run and develop post-exploitation scripts.	WinRM / local	Exec / script
Batch files	Chained native commands for automation on Windows targets.	Local	Automation

> MEMORY HOOK — PSEXEC VS. WMI VS. WINRM
>
> All three run a command on a remote Windows box; the exam separates them by **protocol and footprint**:
>
> **PsExec = SMB (445)**, drops a temporary service → noisy but reliable. **WMI = RPC/DCOM (135)**, fileless → quieter. **WinRM = WS-Man (5985)**, native remoting → blends in on managed networks. If the stem stresses *stealth*, lean WMI or WinRM; if it stresses *reliability* or gives you port 445, lean PsExec.

D · Pivoting — the concept the PBQs love

Pivoting means using a compromised host as a relay to reach a network you cannot touch directly. Box A can see the hidden 10.10.20.0/24; you cannot. So you route your tools *through* A.

TECHNIQUE	HOW IT WORKS
SOCKS proxy + Proxychains	Open a SOCKS proxy on the pivot, then prefix any tool with `proxychains` so its traffic exits through A.
sshuttle	One command turns an SSH session into a transparent route to the target subnet — no per-tool config.
Metasploit autoroute / portfwd	Add a route through an existing Meterpreter session, or forward a single remote port back to your local machine.
Relay creation	Set up a listener/relay (e.g. Responder + ntlmrelayx) to capture and forward authentication to another host.

Exam tell: "the tester cannot reach the internal subnet directly" or "route traffic through the compromised host" = pivoting. The answer is Proxychains, sshuttle, or autoroute — never a scanner.

E · LOLBins — learn the concept, not the whole list

Living off the land binaries are legitimate, signed, pre-installed system tools abused for malicious purposes. Using them avoids dropping detectable custom tools and blends with normal admin activity. The objective lists many; you do not need to memorize all of them individually — recognize the *idea* and know the handful that appear most.

LOLBIN	COMMONLY ABUSED TO…
`rundll32`	Execute code from a DLL (or scriptlet) under a trusted process
`msbuild`	Compile and run inline C# to execute a payload from a trusted binary
[illegible]	[illegible]

`certutil`	Download files or decode base64 payloads (a classic downloader)
`mshta`	Execute HTA / scriptlet content
`findstr` / `strings`	Search files for passwords, secrets, and config data
`net` / `netstat`	Enumerate users, shares, sessions, and connections
`wmic`	Query the system and execute remotely via WMI
`cmd.exe` / `explorer.exe` / `ftp.exe` / `route` / `mmc.exe`	Native execution, file transfer, routing, and management — all trusted, all abusable

> **THE RULE THAT COVERS EVERY LOLBIN QUESTION**
>
> If an option is a **built-in, signed Windows binary being used for something other than its intended job**, it is a LOLBin. You do not need to have seen the specific binary before — the category is the answer.

F · Enumeration once you have moved

After landing on each new host, you re-enumerate. Objective 5.2 lists these as the on-host discovery tasks:

TASK	WHAT YOU ARE LOOKING FOR
Service discovery	Listening services and their ports (the table in section B)
Network traffic discovery	What this host talks to — new subnets, trust relationships
Additional credential capture	New creds cached on this host to reach the next one
Credential dumping	Pull hashes/tickets from memory or the SAM (Mimikatz, secretsdump)
String searches	Grep configs, scripts, and files for passwords and keys (`findstr`)
WMI / WinRM	Both a movement channel and a remote-enumeration channel

5.3 Staging and exfiltration

Two steps: **staging** gathers and prepares the data on a host, then **exfiltration** moves it out — usually through a **covert channel** that hides in traffic the network expects to see. The covert channels are the guaranteed questions here.

A · Staging — prepare before you move it

TECHNIQUE	WHY
File encryption and compression	Shrinks the volume to move and hides content from DLP inspection. A large encrypted archive is the classic staged blob.
Collect to a single location	Consolidate target files on one host before transfer, minimizing the number of outbound connections.

B · Covert channels — memorize these four

A covert channel carries stolen data inside a protocol the network treats as normal, so it slips past monitoring. Each has a distinct tell.

CHANNEL	HOW DATA HIDES	EXAM TELL
DNS	Data is encoded into subdomain lookups (`data.attacker.com`). DNS is almost never blocked, so it tunnels out where nothing else can.	"firewall allows only DNS," "unusual volume of TXT/subdomain queries"
ICMP	Data is stuffed into the payload of ping (echo) packets.	"large or frequent ping traffic," "data in ICMP payload"
HTTPS	Exfil rides inside encrypted web traffic, indistinguishable from normal browsing without TLS inspection.	"blend with normal web traffic," "encrypted outbound"
Steganography	Data is embedded *inside* a carrier file — an image, audio, or video — so the file looks ordinary.	"hidden inside an image," "concealed in a media file"

> **MEMORY HOOK**
>
> **DNS** = escapes when everything else is blocked. **ICMP** = hides in pings. **HTTPS** = hides in encryption. **Steg** = hides in a file. Two hide in a *protocol* (DNS, ICMP), one hides in *encryption* (HTTPS), one hides in a *file* (steg).

C · Exfiltration destinations and tricks

METHOD	NOTES
Alternate data streams (ADS)	An **NTFS-specific** feature that hides data in a secondary stream of a file (`file.txt:hidden.exe`). The stream is invisible to a normal directory listing. A perennial exam favorite — if you see "NTFS" and "hidden data," the answer is ADS.
Email	Attach or embed data and send it out through a trusted mail path.
Cloud storage	Upload to a sanctioned cloud service (Drive, S3, Dropbox) so the traffic looks legitimate.
Cross-account resources	Move data to another account or tenant you control within the same cloud provider.
Text storage sites	Paste data to Pastebin-style services.
Virtual drive mounting	Mount remote/cloud storage as a local drive and copy data across as if it were a normal file operation.

5.4 Cleanup and restoration

Short, conceptual, and carrying one ethics hook the exam loves. The theme: **undo what you did, but never destroy the client's evidence.**

A · The seven cleanup activities

ACTIVITY	WHAT IT MEANS
Remove persistence mechanisms	Delete every scheduled task, service, registry key, cron job, and backdoor you planted.
Revert configuration changes	Restore any setting you altered — disabled AV, firewall rules, modified permissions — to its original state.
Remove tester-created credentials	Delete accounts you created and rotate/remove any keys you added.
Remove tools	Uninstall and delete every binary, script, and payload you uploaded.
Spin down infrastructure	Tear down your C2 servers, listeners, relays, and cloud resources used for the test.
Preserve artifacts	Keep the evidence *you* need for the report — screenshots, logs of your actions, proof of findings — handled securely.
Secure data destruction	Destroy the *client's data you collected*, per the retention terms in the contract, after client acceptance.



The trap: "secure data destruction" and "log cleanup" do **not** mean wiping the client's security logs or forensic trail. You remove *your* tools and data; you *preserve* the client's logs and your own evidence. Destroying the client's logs would be an attacker's move (that's log tampering, a Domain 4 attack technique) and is an ethics failure on the exam.

> **WHY CLEANUP MATTERS — THE EXAM'S REASONING**
>
> Leftover tester artifacts are a real risk: a forgotten backdoor or tester account becomes a genuine vulnerability the moment the engagement ends, and an altered config left in place can break production or weaken security. Cleanup is not tidiness — it is part of "do no harm."

99 Tie-breakers and exam logic

When you are down to two answers, these rules decide it. They are worth more than any single fact in this guide.

SITUATION	THE ANSWER THE EXAM WANTS
Stem says the tester already has a shell and asks “next step”	A Domain 5 task. Eliminate any option about scanning, exploiting, or gaining access.
Goal is to keep access after a reboot	Persistence — scheduled task, service, registry Run key. Not lateral movement.
Target is behind a firewall / NAT and you need a shell	Reverse shell (target connects out). Not bind.
“Execute a command on a remote Windows host” and port 445 is open	PsExec (SMB). If port 5985, WinRM/Evil-WinRM. If stealth is stressed, WMI.
“Dump credentials from memory / LSASS”	Mimikatz.
“Spray one credential across many hosts”	CrackMapExec.
“Reach a subnet the tester cannot access directly”	Pivoting — Proxychains, sshuttle, or Metasploit autoroute.
“Use a trusted built-in binary to avoid detection”	A LOLBin. Pick the native signed binary, not a downloaded tool.
“Only DNS is allowed outbound” and data must leave	DNS tunneling / covert channel.
“Hide data in an NTFS file”	Alternate data streams.
“Hide data inside an image”	Steganography.
Engagement is ending; what about the client’s security logs?	Preserve them. Remove only your own tools, accounts, and data. Never wipe client logs.
Which artifacts do you keep?	Your evidence for the report — screenshots, action logs, proof of findings — stored securely.

Q Self-check — 30 questions

Cover the answer, commit out loud or on paper, *then* reveal. Committing before checking is what turns recognition into recall — and the PBQs test recall.

1 Name the five phases of Domain 5 in order.

> Exploit (Domain 4) → **persistence → lateral movement → staging & exfiltration → cleanup**.

2 A tester wants to keep access to a compromised host even after it reboots. Which phase and which techniques?

> **Persistence (5.1).** Scheduled task, service creation, registry Run key, cron job, new account, or reuse of valid credentials.

3 The target is behind a firewall that blocks all inbound connections. Reverse shell or bind shell, and why?

> **Reverse shell.** The target connects *outbound* to the attacker's listener, which the firewall usually permits. A bind shell would need an open inbound port.

4 Distinguish backdoor, trojan, and rootkit in one line each.

> **Backdoor** = a hidden way back in. **Trojan** = malware disguised as legitimate software. **Rootkit** = malware that hides its own presence, often at kernel level.

5 Which persistence method is the stealthiest because nothing is "installed"?

> **Reusing valid account credentials.** Logins with legitimate creds look like normal activity and survive most cleanup.

6 A tester runs a command on a remote Windows host over SMB (port 445), which drops a temporary service. Which tool?

> **PsExec** (or Impacket's psexec). SMB / 445, temporary service.

7 Which remote-execution method is fileless and rides on RPC/DCOM (port 135)?

> **WMI** (`wmic` / wmiexec). No service dropped, so it is quieter than PsExec.

8 A scenario mentions port 5985 and remote PowerShell. Which tool and protocol?

> **WinRM / Evil-WinRM** over WS-Management (5985, or 5986 for HTTPS).

9 Which tool dumps credentials, hashes, and tickets from LSASS memory?

> **Mimikatz.** Also enables pass-the-hash and pass-the-ticket.

10 A tester has one valid hash and wants to test it against 200 hosts to see where it grants access. Best tool?

> **CrackMapExec (CME).** Built for spraying credentials/hashes across many hosts and reporting access at scale.

11 What is the Python toolkit providing psexec, wmiexec, secretsdump, and ticket attacks?

> **Impacket.**

12 Define pivoting in one sentence.

> Using a compromised host as a relay to route your traffic into a network segment you cannot reach directly.

13 Name three ways to pivot.

> **Proxychains** through a SOCKS proxy, **sshuttle** over SSH, and **Metasploit autoroute/portfwd** through a session. (Relay creation also counts.)

14 What tool forces an arbitrary tool's traffic through a SOCKS proxy on a pivot host?

> **Proxychains.**

15 Define a LOLBin and give two examples.

> A **living-off-the-land binary** — a legitimate, signed, pre-installed system tool abused for malicious purposes to avoid dropping detectable tools. Examples: `rundll32`, `msbuild`, `certutil`, `mshta`, `findstr`.

16 Which LOLBin is commonly abused to download a file or decode a base64 payload?

> **`certutil`.**

17 Match the ports: SMB, RDP, SSH, WinRM, RPC.

> SMB **445** · RDP **3389** · SSH **22** · WinRM **5985/5986** · RPC **135**.

18 Why are cleartext protocols (FTP, Telnet, HTTP) doubly valuable to a tester moving laterally?

> They leak credentials to a sniffer *and* they are easy lateral targets. Traffic capture on these often yields the creds you need for the next host.

19 The only outbound traffic allowed through the firewall is DNS. How might the tester exfiltrate data?

> **DNS tunneling** — encode the data into subdomain lookups. DNS is rarely blocked, so it escapes where nothing else can.

20 Name the four covert channels in the objectives and the essence of each.

> **DNS** (data in lookups), **ICMP** (data in ping payloads), **HTTPS** (data in encrypted web traffic), **steganography** (data inside a carrier file).

21 A tester hides a payload in a secondary NTFS file stream. What is this technique called?

> **Alternate data streams (ADS).** NTFS-specific; invisible to a normal directory listing.

22 What two staging steps commonly precede exfiltration?

> **Compression and encryption** of the collected data, gathered into a single location, to shrink volume and defeat content inspection.

23 During cleanup, should the tester delete the client's security logs to hide their activity?

> **No.** The tester removes their own tools, accounts, and persistence and reverts config changes, but *preserves* the client's logs. Wiping client logs is log tampering — an attacker technique and an ethics failure.

24 What does "secure data destruction" refer to in the cleanup phase?

> Destroying the **client data the tester collected**, per the contract's retention terms, after client acceptance — not destroying the client's own systems or logs.

25 Why is leaving a tester-created account behind a serious problem?

> It becomes a real, live vulnerability the moment the engagement ends — an unmonitored account a real attacker could use. Cleanup is part of "do no harm."

26 A question offers Nmap, sqlmap, PsExec, and Nikto as ways to execute a command on a remote Windows host. How do you eliminate?

> By phase. Nmap = recon, sqlmap and Nikto = web/vuln discovery. Only **PsExec** is a lateral-execution tool. The distractors are real tools from the wrong phase — the standard Domain 5 trap.

27 What is an open-source C2 framework named in the objectives, and what does C2 provide?

> **Covenant.** Command and control manages compromised hosts and channels commands to them — persistence plus control, typically over HTTP/HTTPS.

28 A tester lands on a new host. Name three enumeration tasks they perform there.

> Any three of: service discovery, network traffic discovery, additional credential capture, credential dumping, string searches for secrets.

29 The stem stresses *stealth* for remote execution on a managed Windows network. PsExec, WMI, or WinRM?

> Lean **WMI** (fileless) or **WinRM** (native remoting that blends with admin activity). PsExec drops a service and is the noisier option.

30 A tester needs to reach 10.10.20.0/24, which is only visible from a host they compromised. First move?

> Set up a **pivot** — a SOCKS proxy with Proxychains, sshuttle, or Metasploit autoroute — then run tools through the compromised host into the hidden subnet.

Term list for flashcards

Term on the front, definition on the back. Roughly 45 cards covers the whole domain. Fifteen minutes a day.

TERM	DEFINITION TO RECALL
Persistence	Regaining access without repeating the original exploit; surviving reboots and logouts
Reverse shell	Target connects out to the attacker's listener; beats inbound firewalls
Bind shell	Target opens a listener; attacker connects in; needs an open inbound port
Backdoor	Hidden method of regaining access, bypassing normal authentication
Web shell	Backdoor script on a web server, driven over HTTP
Trojan	Malware disguised as legitimate software
Rootkit	Malware that hides its own presence, often at kernel level
Scheduled task / cron	Runs a payload on a schedule (Windows Task Scheduler / Linux cron)
Service creation	Malicious auto-starting service for boot persistence
Registry Run keys	Launch a payload at logon via HKLM/HKCU Run keys
C2 (command and control)	Framework managing implants and channeling commands (Covenant, Metasploit)
Tampering security controls	Disabling AV/EDR, logging, or firewall rules to protect persistence
Lateral movement	Authenticating to a new host using stolen credentials/hashes/tickets
PsExec	Remote Windows execution over SMB/445; drops a temporary service
WMI / wmiexec	Fileless remote execution over RPC/DCOM (135); quieter than PsExec
WinRM / Evil-WinRM	Remote PowerShell over WS-Management (5985/5986)
Impacket	Python toolkit: psexec, wmiexec, secretsdump, ticket attacks, relaying
CrackMapExec (CME)	Spray a credential/hash across many hosts; check access; execute at scale
Mimikatz	Dump creds/hashes/tickets from LSASS; pass-the-hash / pass-the-ticket
Netcat	Raw TCP/UDP connections; bind/reverse shells; file transfer
Covenant	Open-source .NET command-and-control framework
Pivoting	Using a compromised host to reach a network you cannot access directly
Proxychains	Forces a tool's traffic through a proxy (SOCKS) on a pivot
sshuttle	Transparent VPN-like routing of traffic through an SSH host
Autoroute / portfwd	Metasploit pivoting: route through a session or forward a remote port
Relay creation	Capture and forward authentication to another host (e.g. ntlmrelayx)
LOLBin	Legitimate signed built-in binary abused to avoid detection
rundll32	LOLBin: execute code from a DLL under a trusted process
msbuild	LOLBin: compile and run inline C# from a trusted binary
certutil	LOLBin: download files or decode base64 payloads
findstr / strings	Search files for passwords and secrets

Credential dumping	Pulling hashes/tickets from memory or the SAM
SMB / 445	File sharing; PsExec, admin shares, hash relay
RDP / 3389	Graphical remote logon
SSH / 22	Remote shell and tunneling
RPC-DCOM / 135	WMI execution and DCOM techniques
Covert channel	Stolen data carried inside expected traffic to evade monitoring
DNS tunneling	Exfil encoded into DNS lookups; escapes when other ports are blocked
ICMP tunneling	Exfil hidden in ping (echo) packet payloads
HTTPS exfil	Exfil hidden inside encrypted web traffic
Steganography	Data embedded inside a carrier image/audio/video file
Alternate data streams (ADS)	NTFS feature hiding data in a secondary file stream
Staging	Collecting, compressing, and encrypting data before exfiltration
Preserve artifacts	Keep your own evidence (screenshots, action logs) for the report, stored securely
Secure data destruction	Destroy collected client data per contract after acceptance — never client logs

★ One-page cram sheet

The last thing to read before you walk in. If you can reproduce this page from memory, Domain 5 is finished.

THE TIMELINE (MEMORIZE FIRST)

Exploit → **Persistence** → **Lateral movement** → **Staging & exfil** → **Cleanup**. Every question hangs off placing the task on this line.

FOUR QUESTIONS = FOUR PHASES

Stay? = persistence · Reach next box? = lateral · Get loot out? = exfil · Clean up? = cleanup

SHELLS

Reverse = target reaches out (beats firewalls, the default) · **Bind** = target listens, you connect in (needs open inbound port)

BACKDOOR FAMILY

Backdoor = access · Web shell = backdoor on a web server · Trojan = disguised · Rootkit = hidden

REMOTE EXEC TOOLS

PsExec = SMB/445 (drops service, noisy) · **WMI** = RPC/135 (fileless, quiet) · **WinRM/Evil-WinRM** = 5985 · **CME** = spray at scale · **Mimikatz** = dump LSASS · **Impacket** = Python multi-tool

PORTS

SMB 445 · RDP 3389 · VNC 5900 · SSH 22 · WinRM 5985/5986 · RPC 135 · LDAP 389/636 · FTP 21 · Telnet 23

PIVOTING

Route through a compromised host: **Proxychains** (SOCKS) · **sshuttle** (SSH) · Metasploit **autoroute/portfwd**. Tell: "cannot reach the subnet directly."

COVERT CHANNELS + EXFIL

DNS (escapes blocks) · **ICMP** (pings) · **HTTPS** (encryption) · **Steg** (in a file) · **ADS** (NTFS stream)

LOLBINS

Trusted signed built-in binary used maliciously. rundll32, msbuild, certutil, mshta, findstr, net. Rule: signed built-in doing an odd job = LOLBin.

CLEANUP ETHICS

Remove *your* tools, accounts, persistence, config changes. **Preserve** client logs and your own evidence. Never wipe client logs — that's tampering.

A seven-day plan for this domain

Roughly 30–45 minutes a day, plus lab time on the movement days if you can. Run it in the last two weeks before your exam, after one early read-through.

DAY	FOCUS	PROVE IT
1	Read the guide end to end. Drill the five-phase timeline and the four-questions model.	Write the timeline and the four questions→phases from memory.
2	Objective 5.1 — shells, backdoor family, persistence mechanisms.	Explain reverse vs. bind and backdoor/trojan/rootkit without notes.
3	Objective 5.2 — the tool→phase→protocol master table and the port list.	Reproduce the port table and place five tools on their protocols.
4	Objective 5.2 — pivoting and LOLBins. Lab: run a Proxychains pivot and a PsExec exec.	Describe three pivot methods; state the LOLBin rule.
5	Objective 5.3 — staging, the four covert channels, ADS and exfil destinations.	Match each covert channel to its exam tell; define ADS.
6	Objective 5.4 — the seven cleanup activities and the preserve-vs-destroy ethics hook.	List all seven; explain what you keep vs. destroy vs. never touch.
7	All 30 self-check questions cold, then the keyword tables, then the cram sheet.	Reproduce the cram sheet on blank paper.

If you can build even a tiny lab — one Windows VM and a Kali box — spend an hour running Mimikatz, PsExec, and a Proxychains pivot for real. The performance-based questions in this domain reward the muscle memory of having done it once far more than any amount of rereading.

Study guide for CompTIA PenTest+ PT0-003, Domain 5.0 — Post-exploitation and Lateral Movement. Content organized from the official exam objectives, version 3.0. Objectives and domain weightings are CompTIA's; explanations, tables, hooks, keyword cues, and questions are study aids, not exam content. Every technique here is for authorized testing within an agreed scope only.